Lab 8 — Malware Static Analysis (Safe Sample)

You will profile a *benign* test binary the way an analyst profiles a real malware sample: `file`, `strings`, `sha256sum`, plus an online sandbox lookup.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `file`, `binutils`, `coreutils` (pre-installed) - `yara`

Step 1 — Install yara

```
apt update && apt install -y yara
```

Step 2 — Use the EICAR test string (safe, recognised by every AV)

```
echo 'X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*' > sample.bin
```

This is the industry-standard *fake* malware. It is not harmful, but every AV/sandbox will flag it.

Step 3 — File-type identification

```
file sample.bin
```

`ASCII text` — not an executable, but the *content* is what AV pattern-matches on.

Step 4 — Hash the sample

```
sha256sum sample.bin
```

```
md5sum sample.bin
```

Save the SHA-256. This is the **Indicator of Compromise (IoC)** that you would search VirusTotal or your SIEM for.

Step 5 — Pull printable strings

```
strings sample.bin
```

```
strings -n 6 /bin/ls | head -20
```

Strings expose URLs, file paths, command-and-control hostnames inside real malware.

Step 6 — Write a YARA rule and scan

```
cat > eicar.yar <<'EOF'
```

```
rule EICAR_Test_File {

    meta:

        author = "lab"

        description = "Detects EICAR test string"

    strings:

        $eicar = "EICAR-STANDARD-ANTIVIRUS-TEST-FILE"

    condition:

        $eicar

}

EOF
```

```
yara eicar.yar sample.bin
```

```
yara -r eicar.yar /tmp
```

YARA is the de-facto IoC language used by SOC teams and CERTs.

Step 7 — Look up the hash online (do not upload private samples)

The SHA-256 of EICAR is well known. Search for it on:

- https://www.virustotal.com/gui/search/
- https://bazaar.abuse.ch
- https://malshare.com

You will see hundreds of vendors recognise it.

Free online tools

- **VirusTotal** — multi-engine scanner: https://www.virustotal.com
- **Hybrid Analysis** — free dynamic sandbox: https://www.hybrid-analysis.com
- **ANY.RUN community edition** — https://any.run
- **Joe Sandbox Cloud Basic** — https://www.joesandbox.com
- **MalwareBazaar** — IoC feed: https://bazaar.abuse.ch
- **CyberChef "Defang URL"** recipe — https://gchq.github.io/CyberChef/

What you learned

- The five static-analysis primitives every SOC analyst runs first.
- Why a SHA-256 is enough to pivot across sandboxes and threat feeds.
- How a 5-line YARA rule turns a string into a reusable detection.